

Experiment 9

Compliance Assessments: Test of Design and Test of Operational Effectiveness

Aim

To perform a compliance assessment in Eramba by evaluating compliance requirements through Test of Design (ToD) and Test of Operational Effectiveness (ToOE) and linking them with policies, controls, and risks.

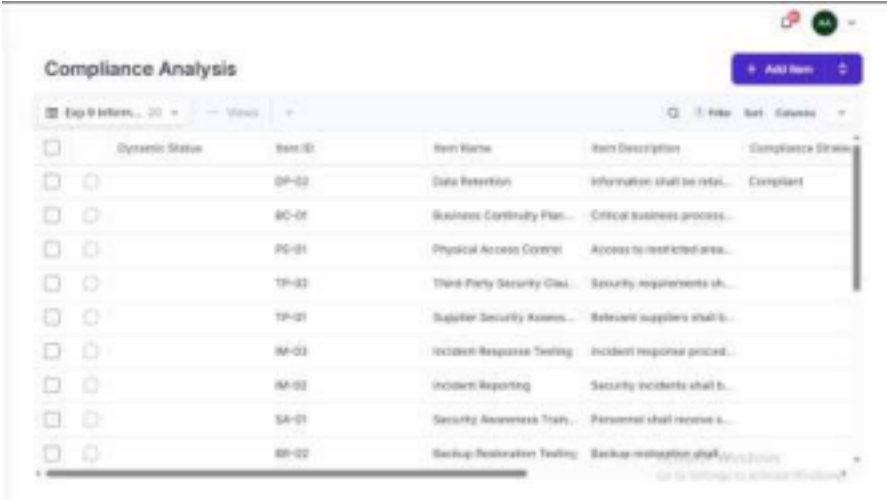
Procedure

1. Log in to the Eramba GRC platform.
2. Navigate to **Compliance Management** → **Compliance Packages**.
3. Create a compliance package named *Exp 9 Information Security Compliance Assessment*.
4. Add compliance requirements to the package using the *Compliance Package Items* section.
5. Import/configure 20 compliance items covering areas such as access control, data protection, incident management, vulnerability management, backup, and business continuity.
6. Navigate to **Compliance Management** → **Compliance Analysis**.
7. Select the created compliance package and view the compliance requirements.
8. Open a compliance item such as **DP-02 – Data Retention**.
9. Configure the Compliance Strategy as *Compliant* and assign the responsible owner.
10. Link relevant internal controls, policies, and business risks to the compliance item.
11. Document the Test of Design (ToD), verifying that the required policy/process is properly designed and documented.
12. Document the Test of Operational Effectiveness (ToOE), verifying that the control is actually operating and supporting evidence exists.
13. Save the compliance assessment and review the resulting compliance status.

Output

A compliance package containing 20 requirements was created and assessed. The selected compliance requirement was configured with a compliance strategy, owner, supporting controls, policies, and

related risks. ToD and ToOE procedures were documented for evaluating both the design and actual operation of the compliance control.



The screenshot shows a web application titled "Compliance Analysis". It features a table with columns: Dynamic Status, Item ID, Item Name, Item Description, and Compliance Strategy. There are 10 rows of data, each with a checkbox in the Dynamic Status column. The items listed are: DP-02 (Data Retention), BC-05 (Business Continuity Plan), PS-01 (Physical Access Control), TP-02 (Third-Party Security Class), TP-01 (Supplier Security Review), IR-03 (Incident Response Testing), IR-02 (Incident Reporting), SA-01 (Security Awareness Training), and BR-02 (Backup-Restoration Testing). A "Add Item" button is visible in the top right corner.

Dynamic Status	Item ID	Item Name	Item Description	Compliance Strategy
☐	DP-02	Data Retention	Information shall be retai...	Compliant
☐	BC-05	Business Continuity Plan...	Critical business process...	
☐	PS-01	Physical Access Control	Access to restricted area...	
☐	TP-02	Third-Party Security Class...	Security requirements sh...	
☐	TP-01	Supplier Security Review...	Relevant suppliers shall b...	
☐	IR-03	Incident Response Testing	Incident response proced...	
☐	IR-02	Incident Reporting	Security incidents shall b...	
☐	SA-01	Security Awareness Train...	Personnel shall receive s...	
☐	BR-02	Backup-Restoration Testin...	Backup restoration shall...	

Fig 1: Compliance Analysis showing the list of compliance requirements



The screenshot shows the "Item detail" page for the "Data Retention" item (DP-02). It includes a "Compliance Item Details" section with fields for Item ID, Item Name, Item Description, and Item Additional Information. Below this is a "General" section with fields for Dynamic Status, Compliance Strategy, Owner, and Findings. The "Owner" field is populated with "Suman Arora".

Compliance Item Details	
Item ID	DP-02
Item Name	Data Retention
Item Description	Information shall be retained and securely disposed of according to defined requirements.
Item Additional Information	ToD: Verify retention and disposal requirements are documented. ToOE: Review retention records and dispose evidence.
General	
Dynamic Status	
Compliance Strategy	Compliant
Owner	Suman Arora
Findings	

Fig 2: DP-02 – Data Retention Item Details with ToD/ToOE information, strategy, and owner

Treatment	
Internal Controls	Backup and Recovery Firewall Management
Policies	Access Control Policy Password Policy
Compliance Exception	
Projects	
Risks	
Asset Risks	
Third Party Risks	
Business Risks	Data Breach Unauthorized Access
Liabilities	Employee Data

Fig 3: Treatment and Risks configuration showing linked controls, policies, business risks, and liabilities

Result

The compliance assessment was successfully configured in Eramba. The system demonstrated how compliance requirements can be evaluated through Test of Design and Test of Operational Effectiveness and connected to organizational controls, policies, and risks.